SenseiBook

Martial Arts Academy Management Web App

Audit report: ippo ulla issues, risks, and world-class aakkaan vendath

Item	Detail
Live URL	https://karate-webapp-e2d53.web.app/
Stack	React 18 + Vite + Tailwind CSS + Firebase (Hosting, Firestore rules) + SweetAlert2 + lucide-react
Firebase project	karate-webapp-e2d53
Files reviewed	firebase.json, firestore.rules, index.html, package.json, package-lock.json, tailwind/postcss/vite config, vercel.json, .env (keys only), .env.example, .firebaserc, .gitignore, README.md
NOT reviewed	**src/ folder** (App.jsx, DojoContext.jsx, components) upload cheythittilla. Athu kondu UI/logic bugs ee report-il illa.
Live app	JS-rendered SPA aayathu kondu login screen / dashboard direct aayi test cheyyaan pattiyilla.

Overall summary

- Foundation nallathaanu: mobile-first dark UI, clear module list (students, attendance, fees, batches, dojos).
- Pakshe ippo ithu **production-ready alla**. Main problem: data LocalStorage-il aanu (README prakaaram), Firestore-il alla. Real dojo-il use cheythal data loss, sync illa.
- Security rules-um login/role setup-um thammil match aakunnilla.
- Findings count: **4 Critical, 6 Important, 10+ improvements**.

Severity	Count	Meaning
CRITICAL	4	Real use-inu munpu fix cheyyanam (data loss / security)
IMPORTANT	6	Quality, reliability, maintainability
UPGRADE	10+	World-class aakkaan venda features

1. Critical issues

C1. Data LocalStorage-il, database-il alla

README-yil *DojoContext.jsx* = "Global state store & LocalStorage persistence", *mockData.js* = seed data ennu paranjirikkunnu. Firebase dependency-um firestore.rules-um und, pakshe data Firestore-ilekku povunnathinte thelivu illa.

Problem	Impact
Phone-il add cheytha student laptop-il kaanilla	Sensei, staff, parent thammil data share aakilla
Browser data clear / phone change	Ellaa student, fee, attendance data poyi
Mock seed data real data-yodu mix aakum	Wrong records, fake students
Backup illa	Recovery impossible

Fix: DojoContext Firestore-ilekku migrate cheyyuka (`onSnapshot` real-time listeners, `addDoc/updateDoc/setDoc`). mockData.js production build-il ninnu remove cheyyuka. Enable Firestore offline persistence.

C2. Auth + custom claims setup illa

Rules `request.auth.token.role` check cheyyunnu. Ee claim set cheyyaan Admin SDK / Cloud Function venam. package.json-il `firebase-functions` / `firebase-admin` illa, login screen-um README-yil illa.

- Login illenkil `isAuthenticated()` ellaam fail aakum, allenkil rules loosen cheythittundaakum (open DB risk).
- Role mismatch: rules-il 'Admin/Sensei/Staff', README-yil 'ADMIN/SENSEI/STAFF'. Case match cheyyanam.
- **Fix:** Firebase Auth (email+password), first admin-nu claim set cheyyaan oru one-time script / Cloud Function, role-based UI guards.

C3. Firestore rules-inte weaknesses

Rule	Problem	Fix
students: read if authenticated	Ethu logged-in user-um ellaa kuttikalude phone, medical info, guardian details vaayikkum	Branch-wise (dojoId) restriction, parent-nu swantham child mathram
activities: create if authenticated	Aarkkum fake activity log create cheyyaam	Staff+ mathram, userId == auth.uid check
payments: create without validation	Negative / fake amount, wrong status write cheyyaam	amount > 0, required fields, allowed modes validate
No field validation anywhere	Malformed data write cheyyaam	Type / size / enum checks
Multi-dojo, but no dojo scoping	Oru branch staff mattu branch data kaanum	Custom claim dojoId + rule check
No default deny at root	New collection add cheythal accidental access	Explicit catch-all deny (Firestore default deny aanu, pakshe document cheyyuka)

C4. API key / env hygiene

- Firebase web API key secret alla (public aayirikkum), pakshe abuse thadayaan restrict cheyyanam: Google Cloud Console - Credentials - HTTP referrers (web.app / localhost).
- **Firebase App Check** enable cheyyuka (reCAPTCHA Enterprise / v3).
- .gitignore-il .env und (nallath). Repo-yil .env commit aayittundo ennu `git log -- .env` check cheyyuka. Aayittundenkil keys rotate cheyyuka.

- Service account JSON / admin keys repo-yil onnum undaakaruth.

2. Important issues

#	Issue	Detail / Fix
I1	Config file names	Upload-il postcss_config.js, tailwind_config.js, vite_config.js, _env, _gitignore, _firebaserc ennu underscores. Real project-il **postcss.config.js, tailwind.config.js, vite.config.js, .env, .gitignore, .firebaserc** aayirikkanam, allenkil build fail aakum.
I2	Two hosting configs	firebase.json (live) + vercel.json. Onnu mathi. Firebase aanu live, athu kondu vercel.json remove cheyyuka. Firebase-il asset caching + security headers add cheyyuka (section 5).
I3	index.html accessibility	`maximum-scale=1.0, user-scalable=no` pinch-zoom block cheyyunnu. Remove cheyyuka. `class="dark"` hardcoded. noscript message illa.
I4	Favicon / meta / PWA	Favicon red layers icon aanu (karate-kku sheri alla). apple-touch-icon, Open Graph / Twitter tags, manifest.json, service worker illa.
I5	Dependencies	firebase ^13.1.0 (lock file-il pinned): clean `npm ci` run aakunnundo verify cheyyuka. firebase-tools heavy, CI-il global install mathi. sweetalert2 + custom Toast randum und: onne mathi (bundle size). Vite 6 → update plan.
I6	Tailwind / fonts	Plus Jakarta Sans load cheyyunnund, pakshe tailwind fontFamily-il define cheythittilla (use aakunnilla). `fontFamily.display` add cheyyuka. Font display=swap check.
I7	README mismatch	README MongoDB (backend-architecture/) + Prisma folders paranjirikkunnu, real stack Firebase. Update cheyyuka. Firebase setup steps + env variables + deploy steps add cheyyuka.

Positives (nallath)

- Mobile-first design, bottom nav, drawer modals, dark theme with clear colour system.
- Role model (Admin / Sensei / Staff) already plan cheythittund.
- SPA rewrite rule firebase.json-il sheri aayi und.
- Vite + Tailwind + React: fast build, modern stack.
- Rules file already und: improve cheythal mathi.

3. World-class aakkaan: features & upgrades

Area	What to add	Priority
Authentication	Firebase Auth login, forgot password, role-based UI (Admin / Sensei / Staff), Parent & Student portal	P0
Database	Firestore sync (real-time), offline persistence, pagination, composite indexes	P0
Security	Hardened rules, App Check, API key restriction, audit log, input validation	P0
Fees & payments	Razorpay / UPI payment link, auto receipt PDF, due reminders, partial payment, discounts / sibling discount	P1
WhatsApp automation	Now only wa.me manual links. Cloud Functions + WhatsApp Business API for fee due / absent alerts	P1
Attendance	QR check-in, streaks, absentee auto-alert, monthly attendance %	P1
Belt & grading	Belt exam module, eligibility rules, exam history, certificate PDF	P1
Tournaments	Event registration, kata / kumite categories, results, medal tally	P2
Reports	Revenue, attendance, growth charts, CSV / PDF export, month-end summary	P1
Student media	Photo upload (Firebase Storage + storage.rules), image compression	P1
PWA	manifest.json, service worker, installable, offline mode, push notifications (FCM)	P1
UX polish	Skeleton loaders, empty states, error boundaries, search + filters, undo, Malayalam / English toggle, light mode	P2
Accessibility	Zoom allow, contrast, ARIA labels, keyboard navigation, 44px touch targets	P1
Performance	Lighthouse 90+, code splitting (React.lazy), WebP images, font-display swap	P2
Quality	Error monitoring (Sentry), analytics, Vitest tests, GitHub Actions CI, ESLint + Prettier	P2
Backup / compliance	Scheduled Firestore export, privacy policy, parental consent (minors' data), data deletion flow	P1

4. Step-by-step roadmap

Phase	Work	Outcome
Phase 0 (1 day)	Config files rename, vercel.json remove, viewport fix, favicon, README update, `npm ci` + `npm run build` verify	Clean, building repo
Phase 1 (2-4 days)	Firebase Auth login, custom claims script, role guards in UI	Secure login
Phase 2 (3-5 days)	DojoContext → Firestore (students, batches, dojos, feePlans, attendance, payments, activities). Remove mockData from prod	Real shared data
Phase 3 (1-2 days)	Hardened Firestore rules + rules unit tests, App Check, API key restriction	Secure data
Phase 4 (1 week)	PWA, offline, push notifications, receipts PDF, reports + export, photo upload	Pro experience
Phase 5 (1-2 weeks)	Payments (Razorpay / UPI), WhatsApp automation via Cloud Functions, belt exams, tournaments	Automation
Phase 6 (ongoing)	Sentry, analytics, tests, CI/CD, Lighthouse tuning, Malayalam i18n, backups	Production grade

5. Ready-to-use config samples

5.1 firebase.json (cache + security headers)

```
{
  "firestore": { "rules": "firestore.rules" },
  "hosting": {
    "public": "dist",
    "ignore": ["firebase.json", "**/.*", "**/node_modules/**"],
    "rewrites": [{ "source": "**", "destination": "/index.html" }],
    "headers": [
      { "source": "/assets/**",
        "headers": [{ "key": "Cache-Control",
                      "value": "public, max-age=31536000, immutable" }] },
      { "source": "**",
        "headers": [
          { "key": "X-Content-Type-Options", "value": "nosniff" },
          { "key": "X-Frame-Options", "value": "DENY" },
          { "key": "Referrer-Policy", "value": "strict-origin-when-cross-origin" },
          { "key": "Permissions-Policy", "value": "camera=(), microphone=()" }
        ] }
    ]
  }
}
```

5.2 index.html viewport fix

```
<meta name="viewport"
  content="width=device-width, initial-scale=1.0, viewport-fit=cover" />
<link rel="manifest" href="/manifest.json" />
<link rel="apple-touch-icon" href="/icons/icon-192.png" />
<meta property="og:title" content="SenseiBook - Dojo Management" />
<meta property="og:description" content="Martial arts academy management" />
<noscript>Please enable JavaScript to use SenseiBook.</noscript>
```

5.3 Hardened Firestore rules (starting point)

```
rules_version = '2';
service cloud.firestore {
  match /databases/{database}/documents {

    function signedIn() { return request.auth != null; }
    function role()     { return request.auth.token.role; }
    function isAdmin()  { return signedIn() && role() == 'Admin'; }
    function isSensei() { return signedIn() && role() in ['Admin','Sensei']; }
    function isStaff()  { return signedIn() && role() in ['Admin','Sensei','Staff']; }
    function sameDojo(d){ return isAdmin() || request.auth.token.dojoId == d; }

    match /students/{id} {
      allow read:   if isStaff() && sameDojo(resource.data.dojoId);
      allow create: if isStaff() && sameDojo(request.resource.data.dojoId)
                    && request.resource.data.name is string
                    && request.resource.data.name.size() between 2 and 80;
      allow update: if isStaff() && sameDojo(resource.data.dojoId);
      allow delete: if isAdmin();
    }

    match /payments/{id} {
      allow read:   if isStaff();
      allow create: if isStaff()
                    && request.resource.data.amount is number
                    && request.resource.data.amount > 0
                    && request.resource.data.mode in
                       ['UPI','Cash','POS','Bank Transfer'];
      allow update, delete: if isAdmin();
    }

    match /activities/{id} {
      allow read:   if isStaff();
      allow create: if isStaff()
                    && request.resource.data.userId == request.auth.uid;
      allow update, delete: if false;
    }

    // dojos, batches, feePlans, attendance: same pattern
    match /{document=**} { allow read, write: if false; }
  }
}
```

Note: ee rules sample aanu. Real collection fields (dojoId, name, amount, mode) app code-yodu match cheyyanam, athu src/ kandittu final aakkaam.

5.4 Set role claim (one-time Node script, run locally)

```
// set-role.js (npm i firebase-admin)
// Service account JSON local-il mathram, repo-yil commit cheyyaruth
import admin from "firebase-admin";
import { readFileSync } from "fs";
admin.initializeApp({ credential: admin.credential.cert(
  JSON.parse(readFileSync("./serviceAccount.json", "utf8"))) });
const user = await admin.auth().getUserByEmail("owner@example.com");
await admin.auth().setCustomUserClaims(user.uid, { role: "Admin" });
console.log("Role set for", user.uid);
```

6. How to test the live app (error check)

Step	How	Look for
1	Chrome - F12 - Console	Red errors, Firebase permission-denied, missing env keys
2	Network tab (reload)	Failed (red) requests, 403 from Firestore, large bundle size
3	Lighthouse (Mobile)	Performance, Accessibility, Best Practices, SEO, PWA scores
4	Real phone test	Bottom nav, drawers, keyboard overlap, safe-area, touch targets
5	Add student on phone, open on laptop	Data kaanunnillenkil = LocalStorage issue (C1) confirmed
6	Clear site data, reload	Data poyo? Seed data thirichu varunnundo?
7	Incognito window	Login required aano? Direct data access undo?
8	Firebase Console - Firestore - Rules playground	Unauthenticated read/write deny aakunnundo

Pre-launch checklist

- [ ] Config files renamed correctly, `npm ci && npm run build` passes
- [ ] Auth + roles working, first Admin claim set
- [ ] All data in Firestore, LocalStorage persistence + mockData removed
- [ ] Hardened rules deployed and tested in Rules Playground
- [ ] App Check on, API key restricted, .env never committed
- [ ] Zoom allowed, favicon + manifest + PWA icons added
- [ ] Lighthouse mobile: Performance & Accessibility 90+
- [ ] Privacy policy + parental consent for minors' data
- [ ] Firestore scheduled backup enabled
- [ ] Custom domain + error monitoring (Sentry) live

Next step

src/ folder zip aakki upload cheyyuka. Appo njan component-wise bugs, state logic, UI issues check cheythu, Auth + Firestore migration code, final rules, PWA setup ennivayokke ezhuthi tharaam.